UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are sourced with a verbatim lecture quote and slide citation.

2. Sourced theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 1 slot / 6 marks. Sourced theory: 23 slots / 94 marks;

   placeholders: 0.
   Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 13 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / sourced / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 1 computed, 23 sourced, 0 placeholder.

PART A - QUESTION 1

A1a - 2 marks - SOURCED

Question:

Explain two preventive network security mechanisms that control traffic flow or provide remote access.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Firewalls control incoming and outgoing traffic based on predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1
2	Remote Access VPN provides secure access to the organization network for individual hosts or clients.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

A1b - 6 marks - SOURCED

Question:

Explain six strengths of using a Network-Based Intrusion Detection System (NIDS).

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Cost of ownership is lower because the IDS is shared across the network.	"Lower because IDS is shared"	062 - Intrusion Detection System, slide 8	062 - Intrusion Detection System::s08::1
2	Packet analysis allows the system to look at all network traffic passing through.	"Can look at all network traffic"	062 - Intrusion Detection System, slide 8	062 - Intrusion Detection System::s08::1
3	Evidence removal is facilitated because packets are captured in a separate machine.	"Packets are captured in a separate machine"	062 - Intrusion Detection System, slide 8	062 - Intrusion Detection System::s08::1
4	Real-time detection and response capabilities allow the system to detect and block DDoS attacks.	"Can detect (and block) DDoS attacks"	062 - Intrusion Detection System, slide 8	062 - Intrusion Detection System::s08::1
5	Operating system independence means the NIDS does not rely on specific host OS features.	"Operating System Independence"	062 - Intrusion Detection System, slide 8	062 - Intrusion Detection System::s08::1
6	It uses a dedicated platform specifically for the purpose of monitoring network activity.	"Uses a dedicated platform for purpose of monitoring network activity"	062 - Intrusion Detection System, slide 5	062 - Intrusion Detection System::s05::1

© Hak Cipta Universiti Teknologi MARA

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 5; 062 - Intrusion Detection System, slide 8

PART A - QUESTION 2

A2a - 2 marks - SOURCED

Question:

List two distinct characteristics of the Vigenere cipher as described in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	It generalizes Caesar's shift cipher	"Vigenere's polyalphabetic cipher (19th century) generalizes Caesar's shift cipher"	031 - Classical Cryptography, slide 14	031 - Classical Cryptography::s14::1
2	It is not amenable to simple frequency analysis	"The Vigenere cipher is not amenable to simple frequency analysis"	031 - Classical Cryptography, slide 14	031 - Classical Cryptography::s14::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 031 - Classical Cryptography, slide 14

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
  R (17) - E ( 4) = 13 -> N
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.

Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

A3a - 2 marks - SOURCED

Question:

State two (2) distinct responsibilities of the Trusted Platform Module (TPM) within the trusted computing architecture.

Marking points:

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	measurement	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1
2	policy enforcement	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 6

A3b - 6 marks - SOURCED

Question:

Refer to your answer in (a). Justify how the TPM supports the Chain of Trust by detailing six (6) specific aspects of its operation or integration as described in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	tamper-resistant hardware module	"Trusted Platform Module (TPM): a tamper-resistant hardware module mounted in a platform."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1
2	protected storage	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1
3	integrity reporting	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1
4	measurements go into PCRs on the TPM	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1
5	chain starts with hardware TPM then software RTM	"The chain starts with the hardware TPM, then software: RTM,TPM Software Stack, BIOS, kernel"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1
6	entire platform verified to be in a trusted state	"At the end, the entire platform is verified to be in a trusted state"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 6; 073 - Trusted Computing, slide 8

PART A - QUESTION 4

A4a - 2 marks - SOURCED

Question:

Explain the two primary motivations for implementing Single Sign-On systems in enterprise environments.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	It reduces the cognitive load on users by decreasing the number of passwords they need to remember.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1
2	It improves operational efficiency by	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1

© Hak Cipta Universiti Teknologi MARA

	minimizing the time users spend entering their credentials repeatedly.			

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 16

A4b - 6 marks - SOURCED

Question:

Discuss six distinct characteristics or components associated with biometric authentication methods as presented in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Biometric systems operate through a structured process that begins with the acquisition of physical traits.	"Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1
2	Fingerprint analysis involves segmenting the print into specific geometric patterns for processing.	"Divides print into loops, whorls and arch"	072 - Biometrics and Authentication, slide 6	072 - Biometrics and Authentication::s06::1
3	The core of fingerprint matching relies on identifying specific unique features within the ridge structure.	"Calculates minutiae points (ridge endings)"	072 - Biometrics and Authentication, slide 6	072 - Biometrics and Authentication::s06::1
4	Iris scanning technology offers a non-intrusive method that does not require physical contact with the sensor.	"No touch required"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1
5	Iris recognition is highly effective because the pattern is visible from a distance without close proximity.	"Iris is coloured and visible from far"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1
6	Alternative user authentication mechanisms include smart cards, biometric methods and two-factor authentication.	"Alternative user authentication mechanisms are smart cards, biometric methods and two-factor authentication."	022 - Identification and Authentication, slide 24	022 - Identification and Authentication::s24::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 24; 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 5; 072 - Biometrics and Authentication, slide 6

PART A - QUESTION 5

A5a - 2 marks - SOURCED

Question:

State two key sources or causes of software insecurity as identified in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Attacker's ability to modify system resources critical for program execution	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer,	051 - Software Security, slide 30	051 - Software Security::s30::1

© Hak Cipta Universiti Teknologi MARA

		function call addresses, interrupt addresses, etc."		
2	Failed validation of user input	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 30

A5b - 6 marks - SOURCED

Question:

Describe six specific security mechanisms, features, or milestones introduced in Windows operating systems according to the provided timeline and security overview.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Introduction of network drivers and TCP/IP in NT 3.51	"NT 3.51 (1993): network drivers and TCP/IP"	041 - Windows Security, slide 2	041 - Windows Security::s02::1
2	Introduction of Active Directory and Kerberos in Windows 2000	"Windows 2000: Active Directory, Kerberos, security architecture."	041 - Windows Security, slide 2	041 - Windows Security::s02::1
3	Implementation of security policies, LAN and wireless security in Server 2003	"Server 2003: security policies, LAN and wireless security"	041 - Windows Security, slide 2	041 - Windows Security::s02::1
4	Removal of admin-by-default status in Vista	"Vista (2007): no "admin-by-default", firewall, DEP"	041 - Windows Security, slide 2	041 - Windows Security::s02::1
5	Introduction of firewall in Vista	"Vista (2007): no "admin-by-default", firewall, DEP"	041 - Windows Security, slide 2	041 - Windows Security::s02::1
6	Introduction of Data Execution Prevention (DEP) in Vista	"Vista (2007): no "admin-by-default", firewall, DEP"	041 - Windows Security, slide 2	041 - Windows Security::s02::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 041 - Windows Security, slide 2

PART A - QUESTION 6

A6a - 2 marks - SOURCED

Question:

List two distinct classes of threats to computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Disclosure is a class of threat involving unauthorized access to information.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1
2	Deception is a class of threat involving the acceptance of false data.	"Deception - acceptance of false data"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 011 - Introduction to Computer Security, slide 10

A6b - 6 marks - SOURCED

Question:

Describe six specific password threats identified in authentication security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Brute force search is listed as a password threat.	"Password Threats Brute force search"	022 - Identification and Authentication, slide 11	022 - Identification and Authentication::s11::1
2	Guessing is listed as a password threat.	"Password Threats Brute force search Guessing"	022 - Identification and Authentication, slide 11	022 - Identification and Authentication::s11::1
3	Dictionary attacks are listed as a password threat.	"Password Threats Brute force search Guessing Dictionary attacks"	022 - Identification and Authentication, slide 11	022 - Identification and Authentication::s11::1
4	Keylogging is listed as a password threat.	"Dictionary attacks Keylogging"	022 - Identification and Authentication, slide 11	022 - Identification and Authentication::s11::1
5	Shoulder surfing is listed as a password threat.	"Keylogging "Shoulder surfing""	022 - Identification and Authentication, slide 11	022 - Identification and Authentication::s11::1
6	Identity spoofing or phishing is listed as a password threat.	""Shoulder surfing" Identity spoofing / phishing"	022 - Identification and Authentication, slide 11	022 - Identification and Authentication::s11::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 11

PART A - QUESTION 7

A7a - 2 marks - SOURCED

Question:

Explain the primary security focus of the Bell-La Padula model and the Biba model as distinct formal security models.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	The Bell-La Padula model is focused on access control only.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1
2	The Biba model provides additional integrity verification.	"Biba model: additional integrity verification"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 5

A7b - 6 marks - SOURCED

Question:

State six key points regarding access control methods, structures, and goals from the lecture evidence.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Access control methods implement policies that control which subjects can access which objects in which way.	"Access control methods implement policies that control which subjects can access which objects in which way."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1
2	Most common practical access control instruments are ACLs, capabilities and various abstractions.	"Most common practical access control instruments are ACLs, capabilities and various abstractions."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1
3	From the design point of view, access control systems can be classified into	"From the design point of view, access control systems can be classified into discretionary (DAC),	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1

© Hak Cipta Universiti Teknologi MARA

	discretionary, mandatory and role-based.	mandatory (MAC) and role-based (RBAC)."		
4	Reference monitors are instruments for realization of access control policies.	"Reference monitors are instruments for realization of access control policies."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1
5	An object is an entity an access to which is requested.	"Object is an entity an access to which is requested."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1
6	Rights represent different types of access.	"Rights represent different types of access."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4

PART A - QUESTION 8

A8a - 2 marks - SOURCED

Question:

State TWO (2) types of malware that are described as malicious programs which replicate themselves or exploit system vulnerabilities to cause harm.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Trojan Horses	"Trojan horses or simply trojans are malicious programs that replicate themselves and steal information or harm the host computer system."	051 - Software Security, slide 12	051 - Software Security::s12::1
2	Computer worms	"Worms are another type of malicious software that exploit a vulnerability in the computer system to cause harm."	051 - Software Security, slide 12	051 - Software Security::s12::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A8b - 6 marks - SOURCED

Question:

State SIX (6) distinct characteristics, impacts, or behaviors associated with malware such as Trojans, worms, or viruses as detailed in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Trojans masquerade as helpful or harmless programs	"They usually masquerade as helpful or harmless programs and begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed."	051 - Software Security, slide 12	051 - Software Security::s12::1
2	Trojans can log keystrokes	"They usually masquerade as helpful or harmless programs and begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed."	051 - Software Security, slide 12	051 - Software Security::s12::1
3	Worms corrupt or	"They usually corrupt or	051 - Software Security,	051 - Software

© Hak Cipta Universiti Teknologi MARA

	delete critical files	delete critical files, consume excess bandwidth and often put the computer under control of the worm author."	slide 12	Security::s12::1
4	Worms consume excess bandwidth	"They usually corrupt or delete critical files, consume excess bandwidth and often put the computer under control of the worm author."	051 - Software Security, slide 12	051 - Software Security::s12::1
5	Worms put the computer under control of the author	"They usually corrupt or delete critical files, consume excess bandwidth and often put the computer under control of the worm author."	051 - Software Security, slide 12	051 - Software Security::s12::1
6	Viruses involve modification of program code	"Modification of program code Viruses and self-replicating code OS and API hooking Control flow hijacking Integer overflow Buffer overflow Heap overflow Format string vulnerabilities Code and data injection Script injection (e.g. XSS) SQL injection"	051 - Software Security, slide 2	051 - Software Security::s02::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12; 051 - Software Security, slide 2

PART A - QUESTION 9

A9a - 2 marks - SOURCED

Question:

Explain two password security controls used to protect stored credentials and manage access.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Password is stored in an encrypted form using a one-way hash function	"Password is stored in an encrypted form using a one-way hash function:"	022 - Identification and Authentication, slide 8	022 - Identification and Authentication::s08::1
2	The hash value of the password becomes a secret key for the client/user	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 19; 022 - Identification and Authentication, slide 8

A9b - 6 marks - SOURCED

Question:

Discuss six authentication mechanisms or controls related to Kerberos design, smartcard usage, or password storage.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Security against eavesdropping by ensuring no password transmission in clear text	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1
2	Reliability requiring every use of a service	"Reliability: every use of a service requires prior	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1

© Hak Cipta Universiti Teknologi MARA

	to require prior authentication	authentication."		
3	Transparency where the user is not aware of any authentication beyond an initial login	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1
4	Scalability to support for a large number of servers and clients	"Scalability: support for a large number of servers and clients."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1
5	Use of physical authentication devices as part of Single Sign-On solutions	"Physical authentication devices"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1
6	Password encryption using DES with a 2-bit salt prepended to the password	"DES prepend password with 2-bit salt"	042 - Linux Security, slide 8	042 - Linux Security::s08::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 042 - Linux Security, slide 8

PART A - QUESTION 10

A10a - 2 marks - SOURCED

Question:

Explain the main concepts of access control by defining a subject and an object, and stating the role of a reference monitor.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	A subject is defined as an entity that initiates an access request.	"Subject is an entity that initiates an access request."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1
2	An object is defined as an entity an access to which is requested.	"Object is an entity an access to which is requested."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 4

A10b - 6 marks - SOURCED

Question:

Explain how access control methods implement policies and classify systems into discretionary, mandatory, and role-based categories, including the function of reference monitors.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Access control methods implement policies that control which subjects can access which objects in which way.	"Access control methods implement policies that control which subjects can access which objects in which way."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1
2	From the design point of view, access control systems can be classified into discretionary (DAC), mandatory (MAC) and role-based (RBAC).	"From the design point of view, access control systems can be classified into discretionary (DAC), mandatory (MAC) and role-based (RBAC)."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1
3	Reference monitors are instruments for realization of access control policies.	"Reference monitors are instruments for realization of access control policies."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1
4	Reference monitors can be deployed at all	"They can be deployed at all levels of system	023 - Access Control and Authorization, slide	023 - Access Control and Authorization::s18::1

© Hak Cipta Universiti Teknologi MARA

	levels of system hierarchy.	hierarchy."	18	
5	Most common practical access control instruments are ACLs, capabilities and various abstractions.	"Most common practical access control instruments are ACLs, capabilities and various abstractions."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1
6	Access control structures are mechanisms for implementing access policies.	"Access control structures are mechanisms for implementing access policies:"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 7

PART B - QUESTION 1

B1a - 5 marks - SOURCED

Question:

Explain the fundamental distinctions between morals, ethics, and laws as frameworks governing human conduct in computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Morals are defined as traditions of belief about right and wrong conduct that serve as the bedrock of social behavior.	"Morals are traditions of belief about right and wrong conduct and "doing what is morally right" is the bedrock of our social behavior"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1
2	Ethics consists of guiding beliefs, standards, or ideals that pervade an individual, group, or community of people.	"Ethics is a suite of guiding beliefs, standards, or ideals that pervades an individual or a group or community of people"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1
3	Laws are formal rules of conduct imposed by a sovereign authority on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1
4	Ethics functions as a documented set of acceptable behaviors specifically for professional or social groups.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1
5	Ethics identifies specific actions as appropriate or inappropriate within the defined context.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 5; 071 - Ethics and Computer Security, slide 6

B1b - 5 marks - SOURCED

Question:

State the defining characteristics of ethics as a framework for professional conduct.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Ethics is characterized as a documented set	"Documented set of acceptable behaviors for professional or social	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1

© Hak Cipta Universiti Teknologi MARA

	of acceptable behaviors tailored for professional or social groups.	groups."		
2	The standards of ethics are explicitly defined by the group itself rather than external imposition.	"Defined by the group."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1
3	Ethics serves to identify specific actions as appropriate or inappropriate for members of the group.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1
4	Professional bodies like the ACM have established codes of ethics and professional conduct for their members.	"Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1
5	Organizations such as the AITP provide forums for networking with experienced peers and other IT professionals.	"provides quality IT-related education, information on relevant IT issues, and forums for networking with experienced peers and other IT professionals."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 7

PART B - QUESTION 2

B2a - 5 marks - SOURCED

Question:

Explain how Trojan horses and computer worms differ in their method of replication and the specific harm they cause to host systems.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Trojan horses masquerade as helpful programs to steal data or delete files.	"They usually masquerade as helpful or harmless programs and begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed."	051 - Software Security, slide 12	051 - Software Security::s12::1
2	Trojan horses are defined by their ability to replicate themselves while stealing information.	"Trojan horses or simply trojans are malicious programs that replicate themselves and steal information or harm the host computer system."	051 - Software Security, slide 12	051 - Software Security::s12::1
3	Computer worms exploit system vulnerabilities to corrupt files and consume bandwidth.	"Worms are another type of malicious software that exploit a vulnerability in the computer system to cause harm. They usually corrupt or delete critical files, consume excess bandwidth"	051 - Software Security, slide 12	051 - Software Security::s12::1
4	Worms often take control of the infected computer to perform unwanted functions like sending spam.	"often put the computer under control of the worm author. Once infected, computer systems are used to send spam mails and perform many such	051 - Software Security, slide 12	051 - Software Security::s12::1

© Hak Cipta Universiti Teknologi MARA

		unwanted functions."		
5	The fundamental distinction lies in Trojans hiding as harmless apps versus worms actively exploiting vulnerabilities.	"Named after the Trojan Horse in Greek mythology, Trojan horses or simply trojans are malicious programs that replicate themselves and steal information or harm the host computer system."	051 - Software Security, slide 12	051 - Software Security::s12::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 12

B2b - 5 marks - SOURCED

Question:

Discuss the primary operational problem caused by Cross-Site Scripting (XSS) attacks regarding user interaction and browser security boundaries.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk
1	Any web application returning unfiltered user input is inherently vulnerable to XSS.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1
2	The core issue is the execution of arbitrary Javascript within the victim's browser.	"Allows execution of arbitrary Javascript in user's browser."	052 - Web Security, slide 13	052 - Web Security::s13::1
3	Users are tricked into triggering this execution through inadvertent clicks on emailed links.	"Inadvertently click on an emailed link"	052 - Web Security, slide 13	052 - Web Security::s13::1
4	Malicious code can also be triggered by hovering over infected images with specific tags.	"Leave a mouse on an image infected with an "onMouseOver" tag."	052 - Web Security, slide 13	052 - Web Security::s13::1
5	XSS violates standard security because injected Javascript originates from a third-party cross-site request rather than the server itself.	"In a XSS attack, Javascript does not originate from a web server but is dynamically injected into it via a user request a following reflection from a third-party, a "cross-site"."	052 - Web Security, slide 14	052 - Web Security::s14::1

Confidence: sourced - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 14

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA